

# Table of Contents

## Cisco Secure Workload — ISO 27001:2022 Compliance Framework

### Technical Runbook | Enterprise Accounts

**Version:** 1.0 | **Standard:** ISO/IEC 27001:2022 (Annex A Controls)

---

### Reader's Guide

**Who this is for.** Organizations pursuing or maintaining ISO/IEC 27001 certification (or transitioning their existing 27001:2013 certification to the 2022 revision), ISMS owners, and internal auditors.

**Questions this runbook helps you answer:**

- *For each Annex A.8 (Technological) control, what specific artifact lands on the certification auditor's desk?*
- *Can my Statement of Applicability reference live, query-able evidence rather than annual screenshots and policy documents?*
- *For the new 2022 controls (A.8.9 configuration management, A.8.16 monitoring activities, A.8.23 web filtering, A.8.28 secure coding), how does workload-resident telemetry contribute?*
- *During a stage-2 certification audit, what part of CSW can I demonstrate live to the auditor — and what's the script for that demo?*
- *For the A.5 Organizational controls around risk and incident management, what does workload telemetry add that policy alone doesn't?*

**What you'll need.** Defined ISMS scope, a current or draft Statement of Applicability (SoA), your risk treatment plan, and your certification body's stage-2 evidence template if available.

**Where to start.** Section 2 maps Annex A controls to CSW capabilities; section 3 covers ISMS deployment patterns; sections 4–5 if you're approaching stage-2 audit or recertification.

---

### CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

| CSW term                                               | Meaning                                              | Why compliance teams care                                  |
|--------------------------------------------------------|------------------------------------------------------|------------------------------------------------------------|
| <b>Scope</b>                                           | Logical boundary (CDE, PHI zone, CUI enclave)        | Defines the systems you must prove are isolated            |
| <b>Label / filter</b>                                  | Tag or query assigning workloads to scopes           | Automates scope membership — reduces drift                 |
| <b>ADM</b>                                             | Application Dependency Mapping from observed traffic | <b>Live</b> network/data-flow diagram for assessors        |
| <b>Workspace</b>                                       | Policy container for one scope or application        | Where allow/deny rules are authored                        |
| <b>Monitor</b> → <b>Simulation</b><br>→ <b>Enforce</b> | Safe rollout sequence                                | Simulation = change-board evidence before blocking traffic |
| <b>Denied Connections</b>                              | Log of flows blocked by policy                       | Primary proof that enforcement <b>operates</b>             |

**Console areas:** Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

**Read next:** [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

## Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

| Phase               | Goal                              | Key CSW actions                                                      | Typical duration |
|---------------------|-----------------------------------|----------------------------------------------------------------------|------------------|
| <b>1 — Coverage</b> | Every in-scope workload in CSW    | Install agents/connectors<br>; apply compliance labels; create scope | Days 1–10        |
| <b>2 — Baseline</b> | Machine-generated flow map        | Run ADM ≥2 weeks; export clusters; app-owner signoff                 | Days 11–28       |
| <b>3 — Policy</b>   | Designed isolation before enforce | Build workspace; Simulation mode; fix false positives                | Days 29–45       |
| <b>4 — Operate</b>  | Continuous proof                  | Enforce; quarterly                                                   | Ongoing          |

| Phase | Goal           | Key CSW actions                              | Typical duration |
|-------|----------------|----------------------------------------------|------------------|
|       | between audits | export pack;<br>ADM refresh<br>every 90 days |                  |

### Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: compliance:<framework>, data:<classification>, env:<tier>
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

### Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle ( $\geq 2$  weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

### Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run  $\geq 1$  week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

### Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

### What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

---

### CSW effectiveness for this framework

- A.8.20–A.8.22 network segregation with workload-resident enforcement
- A.8.16 monitoring evidence from flow + denied-connection logs
- Supplier egress reconciliation via observed outbound flows

**Compared to manual programmes:** static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

---

## 1. Overview

ISO 27001:2022 restructured Annex A from 114 controls across 14 domains to **93 controls across 4 themes**: Organizational, People, Physical, and Technological. CSW addresses the Technological theme controls most directly, with strong contributions to Organizational controls around risk and incident management.

### New in ISO 27001:2022 Relevant to CSW

| New Control                             | Ref    | CSW Relevance                                                                                                                                                             |
|-----------------------------------------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Threat Intelligence                     | A.5.7  | Vulnerability CVE data feeds threat intel posture                                                                                                                         |
| Information Security for Cloud Services | A.5.23 | CSW cloud connectors support cloud inventory and policy context; enforcement depends on sensor / connector coverage and complements cloud-native IAM and network controls |
| ICT Readiness for Business Continuity   | A.5.30 | Policy workspaces exportable for DR; sensor redundancy                                                                                                                    |
| Web Filtering                           | A.8.23 | CSW blocks unauthorized outbound from sensitive workloads                                                                                                                 |
| Secure Coding                           | A.8.28 | Process monitoring detects unexpected code execution                                                                                                                      |
| Data Masking                            | A.8.11 | Enforce encrypted paths; detect plaintext sensitive data flows                                                                                                            |

## 2. Annex A Technological Controls — CSW Mapping

### A.8 — Technological Controls (Primary CSW Domain)

| Control | Name                                 | CSW Implementation                                                                                      |
|---------|--------------------------------------|---------------------------------------------------------------------------------------------------------|
| A.8.15  | Logging                              | Full network + process telemetry; configurable retention                                                |
| A.8.16  | Monitoring Activities                | Real-time anomaly detection; policy violation alerting                                                  |
| A.8.19  | Installation of Software             | Process hash monitoring detects unauthorized software                                                   |
| A.8.20  | Networks Security                    | Micro-segmentation enforces network security at workload level                                          |
| A.8.21  | Security of Network Services         | ADM maps observed network services; policy enforces approved services where CSW enforcement is deployed |
| A.8.22  | Segregation of Networks              | Scope-based isolation (PHI, CDE, production, dev)                                                       |
| A.8.23  | Web Filtering                        | Block unauthorized outbound web access from sensitive scopes                                            |
| A.8.25  | Secure Development Lifecycle         | ADM detects new communication paths introduced by code changes                                          |
| A.8.29  | Security Testing in Dev & Acceptance | ADM baseline comparison pre/post deployment                                                             |

### A.5 — Organizational Controls (CSW Contribution)

| Control | Name                    | CSW Implementation                                           |
|---------|-------------------------|--------------------------------------------------------------|
| A.5.7   | Threat Intelligence     | CVE vulnerability data provides threat-informed risk posture |
| A.5.23  | Cloud Services Security | Cloud connectors support unified visibility                  |

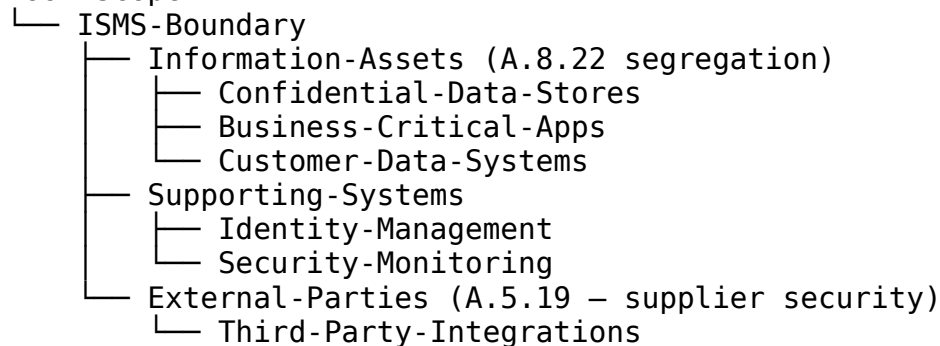
| Control | Name                                     | CSW Implementation                                                                         |
|---------|------------------------------------------|--------------------------------------------------------------------------------------------|
|         |                                          | and policy context across AWS/Azure/GCP, with enforcement dependent on deployment coverage |
| A.5.25  | Information Security Incident Management | Forensic telemetry supports incident response and root cause analysis                      |
| A.5.30  | ICT Readiness                            | Policy workspace backup; simulation mode for DR testing                                    |
| A.5.37  | Documented Operating Procedures          | ADM-generated dependency maps serve as documented network procedures                       |

### 3. CSW Deployment for ISO 27001:2022

#### 3.1 ISMS Scope Definition

Map ISO 27001 ISMS scope to CSW scopes:

Root Scope



#### 3.2 Statement of Applicability (SoA) Evidence

CSW produces evidence for the following SoA controls:

**A.8.15 Logging** → CSW flow + process telemetry export **A.8.16 Monitoring** → Alert history export, anomaly detection log **A.8.20 Network Security** → Policy workspace export, ADM map **A.8.22 Segregation** → Scope membership export, policy enforcement log **A.5.7 Threat Intelligence** → Vulnerability report with CVE mapping **A.5.25 Incident Management** → Forensic telemetry export per incident

### 3.3 Risk Treatment Plan Support

ISO 27001 requires a risk treatment plan. CSW data feeds directly into this:

| Risk Scenario                      | CSW Data Input                  | Treatment                                       |
|------------------------------------|---------------------------------|-------------------------------------------------|
| Unauthorized lateral access        | ADM reveals actual access paths | Micro-segmentation blocks unauthorized paths    |
| Unpatched critical vulnerabilities | CVE scan with CVSS scores       | Prioritized remediation + compensating controls |
| Insider threat / data exfiltration | Outbound flow anomaly detection | Alert + block unauthorized outbound             |
| Third-party compromise             | Partner scope isolation + audit | Restricted access paths + full logging          |
| Cloud misconfiguration             | Cloud connector inventory       | Policy enforcement on cloud workloads           |

## 4. ISO 27001:2022 Audit Evidence Package

| Evidence Item                  | CSW Source                  | Annex A Control | Frequency  |
|--------------------------------|-----------------------------|-----------------|------------|
| Network security policy export | Defend → Policy Workspaces  | A.8.20, A.8.22  | Per audit  |
| Flow telemetry log             | Investigate → Flow Search   | A.8.15, A.8.16  | Continuous |
| Vulnerability report           | Investigate → Vulnerability | A.5.7           | Weekly     |
| Anomaly/alert log              | Alerts → Dashboard          | A.8.16          | Monthly    |
| ADM application map            | Investigate → ADM           | A.8.21, A.5.37  | Quarterly  |
| Incident forensic export       | Investigate → Flow/Process  | A.5.25          | On-demand  |
| Cloud workload inventory       | Manage → Inventory          | A.5.23          | Monthly    |
| Policy change audit trail      | Policy workspace history    | A.8.20          | Per change |

## 5. Certification Readiness Checklist

- ☐ CSW scopes aligned to ISMS boundary
- ☐ Logging retention set (minimum 1 year for ISO 27001)
- ☐ ADM baseline documented and approved

- ☐ All sensitive scopes in enforcement mode
  - ☐ Alert export configured to SIEM
  - ☐ Quarterly ADM re-run scheduled
  - ☐ Vulnerability remediation SLAs defined and tracked
  - ☐ Evidence export tested and validated with auditor format
  - ☐ Policy workspace change process documented
- 

## Related Frameworks

- [NIST SP 800-53 Rev 5](#) — for organisations cross-mapping ISO 27001 to a US federal control catalogue.
  - [NIS2 \(EU 2022/2555\)](#) — Article 21(2) measures map closely to ISO 27001 Annex A controls.
  - [DORA \(EU 2022/2554\)](#) — financial-sector entities typically certify to ISO 27001 *and* report under DORA.
  - [NIST SP 800-207](#) — the segmentation pattern underneath A.8.20–A.8.23.
- 

*Replace [Customer Name] and bracketed fields before customer delivery.*